7. PHÂN LOẠI XSS (3 loại chính)

Reflected XSS (XSS phản chiếu)

Code độc ko đc lưu lại trên server – nó chỉ xuất hiện ngay trong 1 lần request/response rồi biến mất

Ví dụ:

```
site.com/search?q=<script>alert(1)</script>
```

Kết quả in ra

```
<p>Kết quả tìm kiếm cho: <script>alert(1)</script></p>
```

Script chạy ngay khi tải trang, nhưng chỉ ảnh hưởng đến click vào đúng link đó – ko lưu vào database, ko ảnh hưởng ng khác nếu họ ko bấm cùng link

Hacker sẽ phải lừa nạn nhân click vào 1 link chứa sẵn payload (như gửi mail, hay nhận quà trên fb)

Stored XSS (XSS lưu trữ)

Code độc lưu thẳng vào database của server. Ví dụ như lưu trong bảng comments nếu có ai mở trang chứa bình luận đó thì code sẽ tự động chạy – **ko cần click link đặc biệt j cả**

DOM-based XSS

Code ko đi qua server (nó chạy hoàn toàn trong trình duyệt, do chính JavaScript có sẵn trên trang tự đọc dữ liệu từ URL rồi hiển thị ra ko lọc kỹ